
Software Requirements Specification

for

TrustLens

Version 1.1 approved

Prepared by <Name> · <Reg No> · <Branch>

<Institution>

2026-08-23

Table of Contents

1. Introduction	1
1.1 Purpose	1
1.2 Document Conventions	1
1.3 Intended Audience and Reading Suggestions	2
1.4 Product Scope	2
1.5 References	3
2. Overall Description	6
2.1 Product Perspective	6
2.2 Product Functions	6
2.3 User Classes and Characteristics	7
2.4 Operating Environment	8
2.5 Design and Implementation Constraints	9
2.6 User Documentation	9
2.7 Assumptions and Dependencies	10
3. External Interface Requirements	12
3.1 User Interfaces	12
3.2 Hardware Interfaces	12
3.3 Software Interfaces	13
3.4 Communications Interfaces	13
4. System Features	15
4.1 Submission and Evidence Preservation	15
4.2 Normalisation and Evidence Extraction	16
4.3 Rule-Based Detection and Scoring	16
4.4 Explanation of Findings	19
4.5 Analyst Review and Adjudication	20
4.6 Case Management and Report Bundle	20
4.7 Knowledge Base Governance	21
4.8 Identity, Access and Audit	22
4.9 Enrichment and AI Assistance	23
4.10 Analytics	24
5. Other Nonfunctional Requirements	26
5.1 Performance Requirements	26
5.2 Safety Requirements	26
5.3 Security Requirements	26
5.4 Software Quality Attributes	27
5.5 Business Rules	28
6. Other Requirements	29
Appendix A: Glossary	30
Decision quantities	30
Pipeline and domain terms	30
Evidence and provenance grades	31
India-specific terms	31

Organisations	32
Document and programme terms	32
Appendix B: Analysis Models	33
Level 0 — context	33
Level 1 — decomposition	34
Level 2 — process 3.0, evaluate rules and score	37
Appendix C: To Be Determined List	38

List of Figures

Figure 1 — The traceability chain	2
Figure 2 — The staged funnel that Indian digital fraud follows, and the point at which TrustLens acts on it	3
Figure 3 — The eight product functions as a pipeline	7
Figure 4 — Control flow through rule evaluation and scoring, showing both fail-safe exits	18
Figure 5 — The rule lifecycle required by REQ-48, with the rejection path and the rollback that REQ-51 requires	22
Figure B-1 — Level 0 context diagram	33
Figure B-2 — Level 1, panel A: ingest, normalisation, evaluation and explanation	35
Figure B-3 — Level 1, panel B: adjudication and report assembly	35
Figure B-4 — Level 1, panel C: knowledge governance and administration	36
Figure B-5 — Level 2: process 3.0 exploded into five sub-processes	37

Revision History

Name	Date	Reason For Changes	Version
<Name>	2026-08-23	Initial SRS. Functional and nonfunctional requirements imported from PROGRAM-001 v1.1 and restructured to the IEEE 830-1998 / Wiegers template. No requirement was added, removed or reworded during import.	1.0
<Name>	2026-08-23	Editorial and presentational revision. Ten diagrams added (Figures 1 to 5, B-1 to B-5) and Appendix B rewritten to carry them, with Table B-1 registering all eighteen boundary flows and a data-store table added. Section-sign references replaced with spelled-out section names. Reading-suggestion table restated by section name. Two corrections: ASM-009 and ASM-012 were cited by CON-007 and TBD-15 but not reproduced in Section 2.7, and are now listed there; the shall convention in Section 1.2 claimed one occurrence per statement, which fourteen compound statements do not meet, and now states the rule the document actually follows. No requirement was added, removed, renumbered or reworded; REQ-1 to REQ-70 and NFR-1 to NFR-28 are unchanged from v1.0.	1.1

1. Introduction

1.1 Purpose

This document specifies the software requirements for **TrustLens**, release **1.0 (MVP)** — an Indian, explainable, multilingual digital-scam detection, evidence-preservation and assisted-reporting platform.

This SRS covers the **complete TrustLens product**, not a subsystem: submission and evidence preservation, normalisation and extraction, rule-based detection and scoring, explanation, analyst adjudication, case and report-bundle generation, knowledge-base governance, and identity and audit. Capabilities that are planned but outside release 1.0 — enrichment adapters, the AI-assistance layer and analytics — are specified here at Post-MVP priority so that the boundary between what is built now and what is built later is explicit rather than assumed.

The purpose of the document itself is to state what TrustLens must do, precisely enough that a developer can build it, a tester can verify it and a reviewer can confirm that nothing was smuggled in without a source. It deliberately does **not** specify how the software is designed or built.

1.2 Document Conventions

Convention	Meaning
shall	Marks a binding obligation. Each REQ and NFR states one requirement; where that requirement has two inseparable halves — a positive obligation and its matching prohibition — both halves are written with shall in the same statement rather than split across two identifiers. Fourteen statements are compound in this way.
should	A recommendation, not binding, and never used inside a REQ statement.
REQ- <i>n</i>	A functional requirement in Section 4, numbered continuously across all features.
NFR- <i>n</i>	A nonfunctional requirement in Section 5.
FR- <i>nnn</i> / NFR- <i>nnn</i> / CON- <i>nnn</i> / NG- <i>nn</i>	Identifiers from PROGRAM-001, the programme charter. Every REQ cites its origin this way.
ASM- <i>nnn</i> , CONF- <i>nnn</i> , RSK- <i>nnn</i> , G- <i>nn</i> , OI- <i>nn</i>	Entries in the assumption, conflict, risk and gap registers, and the charter's open-issue list.
MP Sec. <i>n</i>	Section <i>n</i> of the Master Execution Prompt, the authoritative programme input.
Figure <i>n</i>	A diagram. Diagrams are normative where they state a flow or an ordering; where a diagram and the prose disagree, the prose governs.
TBD- <i>n</i>	An unresolved item, collected in Appendix C.
<i>DERIVED</i>	The requirement rests on engineering inference, not on a stakeholder statement or an authoritative instruction. See ASM-001.

Priority is stated per requirement, not inherited. A high-priority feature may contain a Post-MVP requirement, and a Post-MVP feature may contain no MVP requirement at all; where the two disagree, the requirement's own priority governs.

Priority	Meaning
M	MVP — release 1.0 is not complete without it
P	Post-MVP — specified now, built in a later release
F	Future — recorded so the architecture does not preclude it. No requirement in release 1.0 carries this priority ; the level exists so that a later one can.

Traceability. Every requirement carries an identifier and a source. The chain is:



Figure 1 — The traceability chain. Every requirement in Sections 4 and 5 can be walked back to a programme input, and forward to the test that verifies it.

Requirements whose source is *DERIVED* have no external authority behind them. They are the first candidates for revision if a real stakeholder becomes available, and they are marked individually rather than disclaimed once in a footnote.

1.3 Intended Audience and Reading Suggestions

Reader	Read first	Then
Developer	2.5 Constraints · 3 External interfaces · 4 System features	5 Nonfunctional requirements · Appendix B analysis models
Tester / QA	4 REQ statements · 5.4 Quality attributes	5.1 Performance targets · Appendix C
Analyst / knowledge editor (end users of the internal tooling)	2.3 User classes · 4.5 Analyst review · 4.7 Knowledge governance	Appendix A glossary
Project sponsor	1.4 Product scope · 2.7 Assumptions · Appendix C	5.5 Business rules
Reviewer / evaluator	Sections 1 and 2 in full	Section 4, then Appendix C to see what is honestly still open

The document is ordered from general to specific. Sections 1 and 2 set context and can be read on their own. Section 3 defines the boundary between TrustLens and everything outside it. Section 4 holds the functional detail and is the section a developer works from. Section 5 states the qualities the system must exhibit regardless of feature. Appendix C lists everything not yet decided — read it before treating any part of this SRS as settled.

1.4 Product Scope

Digital fraud in India operates as a staged funnel: contact -> pretext -> trust or fear escalation -> credential or payment request -> post-action suppression. Victims are manipulated into performing the harmful act themselves — entering a UPI PIN, scanning a QR code, installing an app, or paying a "fine" to someone impersonating a police officer.

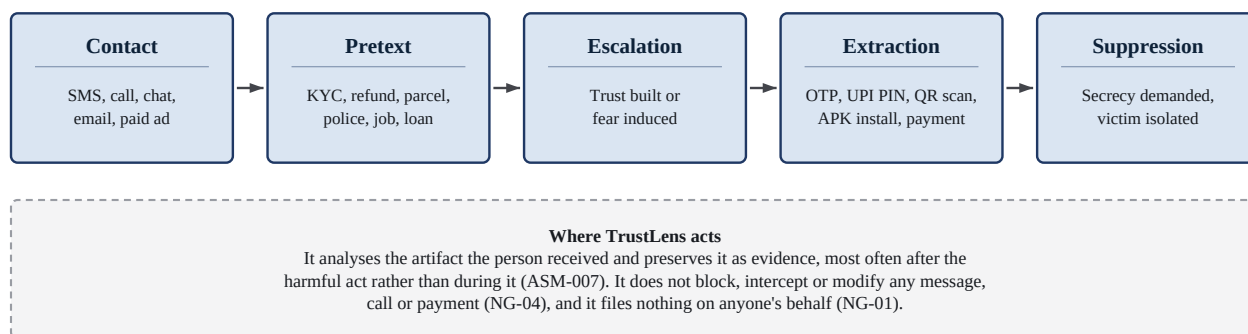


Figure 2 — The staged funnel that Indian digital fraud follows, and the point at which TrustLens acts on it. The product analyses the artifact; it never intervenes in the channel.

A large body of official anti-fraud guidance already exists across I4C, CERT-In, RBI, NPCI, SEBI and DoT.

That guidance is not in a machine-usable form: it is scattered across advisory PDFs and press releases, written for human readers, and it goes stale. TrustLens exists to close the gap between published official guidance and a decision a person can act on and verify, at the moment they need it.

Objectives.

1. Return a verdict on submitted content that separates **risk** from **confidence** and shows the evidence for both.
2. Make every finding traceable from submitted content -> extracted indicators -> matched rules -> score contributions -> the official source that supports the rule.
3. Preserve submitted evidence with integrity metadata and assemble it into a report bundle the user can take to an authority.
4. Make a decision made today reproducible exactly, months later, from stored evidence and the pinned rule-set version.

Explicitly out of scope. TrustLens shall not: submit reports to any authority automatically (NG-01); issue official determinations of fraud (NG-02); give legal advice (NG-03); block, intercept or modify messages, calls or payments (NG-04); run as a device agent or read device state (NG-05); claim detection accuracy without reproducible evaluation (NG-06); allow an AI model to be the final decision authority (NG-07); self-learn from user feedback without human adjudication (NG-08); identify or profile individual suspected offenders (NG-09); or retain submitted content beyond its defined retention class (NG-10).

A stated limitation, not a defect. No labelled real-world corpus of Indian scam messages exists or is obtainable within this programme (G-09). Precision, recall, false-positive rate and calibration therefore **cannot be measured**, and no accuracy claim appears anywhere in this document. What *can* be proven — determinism, traceability, explainability completeness and schema conformance — is specified in Section 5.4 with verification methods attached.

1.5 References

#	Document	Version / Date	Location
R1	TrustLens Master Execution Prompt	Supplied, authoritative	Programme input, cited as MP Sec . n

#	Document	Version / Date	Location
R2	TrustLens Phase One Research Foundation	Supplied, secondary/unverified	Programme input, cited as RP p.n
R3	PROGRAM-001 — Program Charter	v1.1, 2026-08-14	docs/00-program/PROGRAM-001-program-charter.md
R4	BASELINE-001 — Repository Assessment	v1.0	docs/00-program/BASELINE-001-repository-assessment.md
R5	GATE-001 — Phase 1 Gate Assessment	2026-08-14	docs/00-program/GATE-001-phase-1-assessment.md
R6	Glossary — controlled vocabulary (normative)	v1.0	docs/00-program/glossary.md
R7	Assumption Register	v1.1	docs/00-program/assumption-register.md
R8	Conflict Register	v1.0	docs/00-program/conflict-register.md
R9	Risk Register	v1.0	docs/00-program/risk-register.md
R10	RESEARCH-001 — Source Inventory (26 sources, 11 verified)	v1.1	docs/01-research/RESEARCH-001-source-inventory.md
R11	RESEARCH-002 — Scam Taxonomy (10 categories, 41 subcategories)	v1.1	docs/01-research/RESEARCH-002-scam-taxonomy.md
R12	RESEARCH-004 — Evidence Matrix (30 rules graded)	v1.1	docs/01-research/RESEARCH-004-evidence-matrix.md
R13	RESEARCH-005 — Research Gap Register (22 open gaps)	v1.1	docs/01-research/RESEARCH-005-gap-register.md
R14	ADR-0001 — Adopt the supplied technical baseline	Accepted 2026-07-31	adr/ADR-0001-adopt-technical-baseline.md
R15	ADR-0002 — Defer the Python intelligence service	Accepted 2026-07-31	adr/ADR-0002-defer-python-intelligence-service.md
R16	ADR-0003 — Rule representation format	Accepted 2026-08-15	adr/ADR-0003-rule-representation-format.md
R17	Rule JSON Schema (draft 2020-12)	schema_version 1.0	knowledge/schemas/rule.schema.json

#	Document	Version / Date	Location
R18	Source verification manifest	2026-08-14	knowledge/sources/verification-manifest.json
R19	IEEE Std 830-1998, <i>Recommended Practice for Software Requirements Specifications</i>	1998	IEEE
R20	K. E. Wieggers, <i>Software Requirements Specification template</i>	1999	Template used for this document
R21	TrustLens DFD set — levels 0, 1 and 2, PlantUML source	2026-08-23	docs/05-architecture/diagrams/ (rendered in Appendix B)

2. Overall Description

2.1 Product Perspective

TrustLens is a **new, self-contained product**. It is not a replacement for an existing system, not a member of a product family, and it does not extend any incumbent tool. There is no legacy codebase, no inherited data model and no prior deployment (R4).

It is, however, **not self-sufficient in knowledge**. Its detection ability is entirely a function of a curated knowledge base derived from published official guidance, which reaches the system through a governed human-mediated pipeline rather than an automated feed (see Section 2.7 and G-01 to G-04). A TrustLens with an empty rule set is a working system that detects nothing.

The product boundary and the flows crossing it are specified as a level-0 data flow diagram in Appendix B, Figure B-1, and every boundary-crossing flow is registered in Table B-1. In summary, TrustLens exchanges data with nine external entities:

External entity	Direction	Nature of exchange
Reporting user	both	Submits artifacts and corrections; receives verdict, explanation and report bundle
Analyst	both	Receives queued uncertain cases; returns adjudications
Administrator	both	Supplies configuration and retention policy; receives health, audit and metrics
Report recipient (authority, bank, portal)	outbound	Receives an access-controlled report export — never an automatic submission
Official guidance bodies (I4C, CERT-In, RBI, NPCI, SEBI, DoT)	inbound only	Published advisories, consumed one way and graded before use
Knowledge editor	both	Submits draft rules; receives schema and lint verdicts
Knowledge approver	both	Receives review packages; returns publication decisions
URL / threat-intelligence providers (<i>Post-MVP</i>)	both	Reputation lookups and non-authoritative verdicts
AI assist provider (<i>Post-MVP</i>)	both	Isolated content prompts out; schema-checked drafts back

2.2 Product Functions

At the highest level TrustLens performs eight functions, summarised in Figure 3. These correspond one-to-one with the processes in the level-1 data flow diagram (Appendix B, Figures B-2 to B-4), so the two representations can be checked against each other.

- **Ingest and preserve evidence** — accept submitted artifacts, validate them, hash each item and record chain-of-custody metadata.
- **Normalise and extract** — convert content to canonical form, identify language and script, and extract entities, indicators and negative indicators.
- **Evaluate rules and score** — run a pinned, versioned rule set deterministically over the extracted evidence, computing risk, confidence, severity and evidence quality as separate quantities.
- **Compose explanation** — report what matched, what was considered and did not match, what reduced risk, why confidence is limited, and which official source supports each finding.

- **Route and adjudicate** — send cases past the uncertainty threshold to an analyst, and record the adjudication with its rationale.
- **Assemble report bundle** — build a reproducible, exportable package from a case, carrying the non-official-determination disclaimer.
- **Govern the knowledge base** — grade sources, validate and lint draft rules, run the review and approval lifecycle, publish and roll back rule-set versions.
- **Administer, audit and observe** — authenticate users, enforce role-based access, apply retention policy, and write immutable audit events.

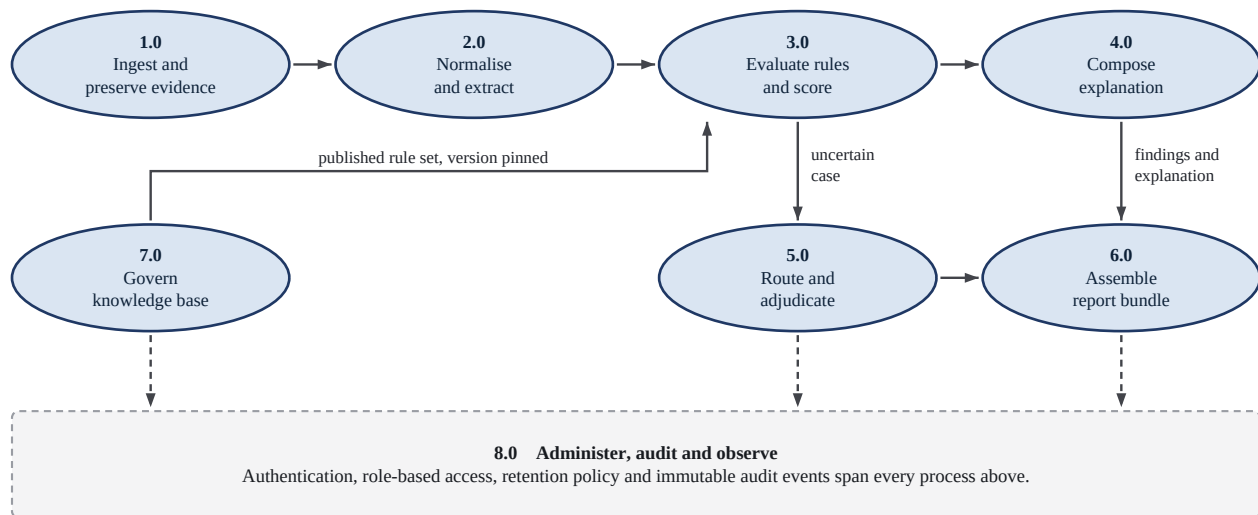


Figure 3 — The eight product functions as a pipeline. Function 7.0 supplies the rule set that 3.0 evaluates; function 8.0 spans all of them. Numbering matches the level-1 model in Appendix B.

2.3 User Classes and Characteristics

Six user classes are anticipated. The first two are the classes whose satisfaction determines whether the product succeeds; the rest are internal operators.

All six are DERIVED. No end user, analyst, knowledge editor or administrator was available to validate any of these characterisations (ASM-001). This is the single largest source of requirement risk in the document.

Class	Frequency	Technical expertise	Privilege	Characteristics and needs
Reporting user — general (P1)	Occasional, under time pressure	Low; comfortable with UPI and messaging, not technical	Own data only	Salaried, urban, ~30 seconds of patience, mildly anxious. Needs a fast plain verdict and one clear next step. Fails if the answer is hedged into meaninglessness or jargon-heavy. Most important class to satisfy.

Class	Frequency	Technical expertise	Privilege	Characteristics and needs
Reporting user — high-harm (P2)	Rare, in crisis	Low; defers to authority	Own data only	Retired, WhatsApp-first, targeted by coercion scams such as digital arrest. Needs a calm, unambiguous contradiction of the scammer's claim and explicit permission to involve family. Fails if the system equivocates or amplifies panic.
Analyst (P3)	Daily	High, domain-expert	Read all cases; adjudicate	Reviews queued uncertain cases. Needs full score decomposition and to see what did <i>not</i> match. Fails if she cannot see why the engine concluded what it did.
Knowledge editor (P4)	Weekly	High, domain-expert	Author rules; no publish	Converts new advisories into rules. Needs a schema that makes a well-formed rule easy and a malformed one impossible. Fails if authoring a rule requires touching engine code.
Knowledge approver (P5)	Weekly	High	Publish, reject, roll back	Gate-keeps publication. Needs diff, impact analysis and regression results before approving. Fails if rules reach production unreviewed.
Administrator (P6)	As needed	High, operational	Full configuration; no case content	Operates the platform. Needs health signals, rollback and retention controls, without needing access to submitted content.

Two further parties interact with the product but are **not user classes**: *official guidance bodies*, whose published material is consumed one way, and *report recipients*, who receive an exported bundle but do not operate the software.

2.4 Operating Environment

Element	Specification
Client	Modern evergreen browsers on mobile and desktop — Chrome, Safari, Firefox, Edge. Mobile-first: the primary user is assumed to be on a phone (ASM-007). No native mobile application in release 1.0.
Frontend runtime	React with TypeScript (strict mode)
Core backend runtime	Java 21 with Spring Boot 3.x, structured as a modular monolith (R14)
AI / advanced extraction runtime	Python with FastAPI, as a separately deployable service — deferred to the AI phase (R15)
Primary datastore	PostgreSQL 16
Local environment	Docker and Docker Compose
CI/CD	GitHub Actions
Deployment target	Local and test environments only during this programme; no production deployment occurs (ASM-013). The hosted target is undecided — TBD-6.

Environment dependency. Java 21.0.11, Maven 3.9.11 and Node 26.0.0 are present on the development machine. **Docker and PostgreSQL are not installed** (RSK-006, OI-02). This does not affect specification work but blocks implementation.

2.5 Design and Implementation Constraints

ID	Constraint	Origin
CON-001	No automatic submission of legal or regulatory reports.	MP Sec . 1, NG-01
CON-002	No accuracy claim unsupported by reproducible evaluation on a described dataset.	MP Sec . 17
CON-003	The rule engine is the primary decision authority; AI output is non-authoritative and advisory.	MP Sec . 3
CON-004	No fabricated advisories, citations, statistics, regulatory obligations or datasets.	MP Sec . 2 and 21
CON-005	Synthetic examples shall be labelled synthetic and never presented as real samples.	MP Sec . 8 and 21
CON-006	Docker and PostgreSQL are absent from the development machine; implementation is blocked until installed.	RSK-006
CON-007	Delivery capacity is one engineer plus AI assistance.	RSK-005, ASM-012
CON-008	Java 21 + Spring Boot core and React/TypeScript frontend; the Python intelligence service is deferred.	R14, R15
CON-009	Rules are versioned JSON data validated by a published JSON Schema plus a cross-file linter — never engine code. A new scam type is added by writing one JSON file.	R16
CON-010	Rule identifiers are neutral (TL - <domain> - <nnn>); source attribution is carried as data, never embedded in a key.	CONF-005
CON-011	No rule may be satisfiable by a single indicator, and no rule may be satisfiable by weak indicators alone; this is enforced mechanically at load time.	CONF-002, R16
CON-012	Severity is an ordinal from LOW to CRITICAL. Numeric risk or confidence values shall not be stored on a rule; the research package's 0 to 100 scores are retained only as non-operational provenance.	CONF-001, R16
CON-013	Three starter rules require evidence TrustLens cannot observe (device network state, user journey, live payment flow). They are retained as DEFERRED with a blocked_by reason and shall not be published.	CONF-003

2.6 User Documentation

The following shall be delivered with the software. Formats are HTML for online material and PDF for anything intended to leave the system with a user.

Component	Audience	Content
In-product help and first-run guidance	Reporting user	What TrustLens does and does not do; what the disclaimer means; how to read a verdict
Verdict reading guide	Reporting user	How to interpret risk versus confidence, and what INSUFFICIENT_EVIDENCE means
Report bundle README	Reporting user, report recipient	Bundle contents, hash verification steps, the non-official-determination statement
Analyst adjudication guide	Analyst	Queue workflow, score decomposition, override and rationale recording
Rule authoring guide	Knowledge editor	Rule schema walkthrough, worked examples for each rule shape, lint error catalogue

Component	Audience	Content
Approval and rollback runbook	Knowledge approver	Diff review, impact analysis, regression evidence, rollback procedure
Operations runbook	Administrator	Configuration reference, retention controls, health checks, backup and recovery
API reference	Integrator, developer	Generated from the OpenAPI specification

2.7 Assumptions and Dependencies

Assumptions

ID	Assumption	Confidence	Effect if wrong
ASM-001	No end-user, analyst or official-body stakeholder is available; all personas, journeys and <i>DERIVED</i> requirements are engineering inference.	LOW — load-bearing	Requirements may target the wrong users and journeys. Sections 2.3 and 4 would need rework.
ASM-002	Deployment is single-tenant; multi-tenancy is Future scope.	HIGH	Tenant isolation must be retrofitted into the data model.
ASM-003	MVP is English-first: the architecture is multilingual, the content is not.	MEDIUM	The product fails its stated core audience (CONF-004, TBD-4).
ASM-004	No real user data is processed during the programme; all examples are synthetic and labelled.	HIGH	Privacy and consent obligations activate immediately.
ASM-005	No budget exists for paid threat-intelligence providers; adapters target free tiers or are stubbed.	MEDIUM	Provider selection changes.
ASM-007	Users submit content after the fact , primarily on mobile, not during a live attack.	MEDIUM	UX and latency budgets change materially.
ASM-008	TrustLens holds no regulatory registration, official status or relationship with any cited body.	HIGH	Legal posture and disclaimer requirements change.
ASM-009	No fixed programme end date exists; scope is staged by dependency, not by calendar.	MEDIUM	No requirement in this document can be time-boxed (TBD-15).
ASM-011	PostgreSQL 16 runs via Docker Compose in local development.	MEDIUM	Neither is currently installed (RSK-006).
ASM-012	Delivery capacity is one engineer plus AI assistance.	HIGH	Sequencing and parallelisation change; this is the origin of CON-007.
ASM-013	No production deployment occurs during this programme.	MEDIUM	Security, scaling and operational requirements escalate sharply.
ASM-014	Default evidence retention is 90 days, pending a real policy decision.	LOW	Retention, deletion and storage design change (TBD-5).
ASM-015	Unverified: India's Digital Personal Data Protection Act 2023 is <i>likely</i> to apply. No legal verification has been performed and no compliance claim is made.	LOW	Privacy design may be materially incomplete or misdirected. Requires qualified legal review, not engineering inference.
ASM-017	Submitted content routinely contains live sensitive data — OTPs, account numbers, VPAs, names — and must be treated as sensitive from ingest, before any classification decision.	HIGH	Privacy exposure and log leakage.

ID	Assumption	Confidence	Effect if wrong
ASM-018	The analysis latency budget is seconds, not milliseconds.	MEDIUM	Architecture may need asynchronous processing earlier than planned.
ASM-019	During development, rule authoring and approval are performed by the same person; separation of duties is modelled in the system but not enforced organisationally.	HIGH	No technical impact — the workflow is still built and tested with distinct roles.

Dependencies

Dependency	Nature	Consequence
Official-source retrieval is partly manual	i4c.mha.gov.in, pib.gov.in and npc1.org.in systematically block automated retrieval; cert-in.org.in, niti.gov.in and rbi.org.in permit it. Established empirically, not assumed.	Any advisory-ingestion capability shall assume a human-in-the-loop retrieval step. Full automation is not achievable (G-01 to G-04, G-21).
Knowledge base completeness	26 sources graded, 11 verified; 30 starter rules graded, 18 evidenced <i>and</i> implementable.	Detection coverage at release is bounded by evidence, not by engine capability.
Negative-indicator library	The research package supplies 12 positive indicator families and zero suppressive signals.	Without it the false-positive problem is unsolvable (G-07). It is the highest-priority knowledge work package.
No labelled corpus	None exists and none is obtainable within the programme.	Accuracy is unmeasurable (G-09, RSK-003). Constrains Section 5.4 to provable attributes only.
Docker + PostgreSQL installation	Not present on the development machine.	Blocks implementation entirely (OI-02, RSK-006).
Third-party providers (<i>Post-MVP</i>)	URL/threat-intelligence services and an AI provider.	The core path shall complete with any single provider unavailable (REQ-60, REQ-65).
OCR engine (<i>Post-MVP</i>)	Required for screenshot submission; no guidance retrieved on OCR quality for Indian scripts.	Evidence-quality scoring for OCR output is unspecified (G-15, TBD-8).

3. External Interface Requirements

3.1 User Interfaces

TrustLens presents a single responsive web application, mobile-first, with role-conditioned navigation. There is no separate installable client in release 1.0.

Screens.

Screen	Primary class	Purpose
Submit	P1, P2	Paste or upload content, add optional sender and channel context, submit
Verdict	P1, P2	Plain-language outcome, risk and confidence shown separately, next steps, "why" expander
Evidence detail	P1, P3	Indicators found, rules matched, rules considered and not matched, source citations
Correction	P1	Amend an extracted entity and re-run the evaluation
Case	P1, P3	Submissions, findings, notes and bundle export for one incident
Review queue	P3	Uncertain cases with full score decomposition and adjudication controls
Rule authoring	P4	Draft a rule, run validation, read lint errors
Approval	P5	Diff, impact analysis, regression results, publish / reject / roll back
Administration	P6	Configuration, thresholds, retention, feature flags, health

Standards binding on every screen.

- WCAG 2.2 AA on all MVP journeys, verified by automated and manual audit.
- Risk and confidence shall never be merged into a single number, bar or colour in any view.
- Every verdict view shall carry the non-official-determination disclaimer without requiring interaction to reveal it.
- The plain-language explanation is the default view; the technical decomposition is one deliberate action away, never the landing state for P1 and P2.
- Supported languages are stated in the interface; unsupported input is flagged explicitly rather than silently returning a weak result.
- Error messages shall state what went wrong and what the user can do next, and shall never include raw submitted content, secrets or internal identifiers.

Detailed layout, interaction and visual design are **out of scope for this SRS** and belong to a separate user-interface specification.

3.2 Hardware Interfaces

None. TrustLens is a browser-delivered web application with no direct hardware dependency. It does not interface with device sensors, SIM or telephony hardware, card readers, or any physical peripheral. Camera and file-system access, where used for screenshot upload, occur entirely through standard browser APIs; the software has no knowledge of the underlying device.

This is a deliberate boundary, not an omission: NG-05 places device-agent behaviour out of scope, and CON-013 records the three rules that consequently cannot be implemented.

3.3 Software Interfaces

#	Component	Version	Data in	Data out	Purpose
SI-1	PostgreSQL	16	Evidence records, cases, findings, pinned analyses, audit events	Same on read	Primary datastore. Access via connection pool over TLS.
SI-2	Rule JSON Schema (R17)	schema_version 1.0	Rule documents at load time	Validation verdict	The single authority on rule structure. The Java loader shall validate against this schema file itself, not a reimplementations of it.
SI-3	Cross-file rule linter (R16)	—	Rule set, indicator registry, taxonomy, verification manifest	Lint verdict with layer attribution	Enforces constraints a single-document schema cannot express. Runs in CI before any rule reaches a published set.
SI-4	Source verification manifest (R18)	2026-08-14	Source identifiers	Verification status and grade	A rule may not claim a grade the manifest contradicts.
SI-5	OCR engine (Post-MVP)	TBD-8	Image artifacts	Extracted text with per-block confidence	Screenshot submission. Confidence feeds evidence quality.
SI-6	URL / threat-intelligence providers (Post-MVP)	Provider-agnostic adapter	URL, domain	Reputation verdict, labelled non-authoritative	Enrichment. Multiple providers behind one interface.
SI-7	AI assist provider (Post-MVP)	Provider-agnostic adapter	Isolated content prompt	Schema-constrained JSON	Extraction assistance and draft rule suggestions. Output is advisory, never authoritative.
SI-8	Identity provider	TBD-7	Credentials or federated assertion	Authenticated principal with roles	Authentication and role assignment.

Shared data. The rule set, indicator registry and scam taxonomy are shared between the knowledge-governance function and the detection function. They shall be shared as **immutable versioned snapshots**, not as a mutable store both sides write to: an evaluation pins the rule-set version it used, so publication of a new version cannot retroactively change a completed analysis.

3.4 Communications Interfaces

Interface	Specification
Client <->server	HTTPS only. TLS 1.3. Versioned REST over JSON.
API style	Versioned REST described by an OpenAPI document from which the published reference is generated. Asynchronous messaging shall be introduced only where workload or reliability justifies it, not by default.
Outbound enrichment (Post-MVP)	HTTPS to provider endpoints, with per-provider timeout and circuit breaking. A provider failure shall degrade the result, never fail the submission.

Interface	Specification
Report export	Authenticated, access-controlled download over HTTPS. There is no outbound transmission of a report to any authority, by any protocol — this is enforced by the absence of the capability, not by configuration (NG-01).
Email / SMS	TrustLens sends no SMS and no scam-related notification traffic. Transactional email, if introduced, is limited to account and access functions.
Correlation	Every request carries a correlation identifier propagated through logs and audit events.
Data formats	JSON for API payloads; UTF-8 throughout, with the original byte sequence of submitted content preserved unmodified alongside its normalised form.
Rate limiting	Public endpoints shall be rate-limited and protected against abuse (Post-MVP, REQ-70).

4. System Features

Ten features. Each states its priority, the stimulus/response sequences that exercise it, and its functional requirements. Every REQ cites the charter identifier it came from; requirements marked *DERIVED* have no external authority behind them.

4.1 Submission and Evidence Preservation

4.1.1 Description and Priority

Accepts content from a reporting user, validates it, and preserves each item with integrity metadata before any analysis occurs. Preservation happens **first** — evidence is hashed on ingest, so its integrity does not depend on what the analysis later concludes.

Priority: High. (*benefit 9, penalty 9, cost 3, risk 4*)

4.1.2 Stimulus/Response Sequences

#	Stimulus	Response
S1	User pastes SMS or chat text and submits	System accepts the artifact, hashes it, records capture time and chain-of-custody metadata, creates a submission, and begins analysis
S2	User submits a URL alongside the message text	System groups both artifacts into one submission and one case
S3	User uploads a screenshot exceeding the size limit or of an unsupported type	System rejects the upload before processing, states the limit and the accepted types, and preserves the rest of the submission
S4	User adds optional sender, channel and description	System stores the context and makes it available to extraction as user-supplied, distinguishable from content-derived data

4.1.3 Functional Requirements

ID	Requirement	Pri	Source
REQ-1	The system shall accept free-text submission of SMS, WhatsApp or other chat message bodies.	M	FR-001
REQ-2	The system shall accept URL submission.	M	FR-002
REQ-3	The system shall accept email content including headers.	M	FR-003
REQ-4	The system shall accept screenshot and image upload.	P	FR-004
REQ-5	The system shall group multiple artifacts into a single submission and a single case.	M	FR-005
REQ-6	The system shall validate media type, size and structure before processing, and shall reject unsafe uploads without processing them.	P	FR-006
REQ-7	The system shall accept optional user-supplied context comprising sender, channel and description.	M	FR-007
REQ-8	The system shall compute and store a cryptographic hash of every evidence item on ingest, together with chain-of-custody metadata.	M	FR-050
REQ-9	The system shall retain the original submitted content unmodified alongside any normalised form derived from it.	M	FR-010

4.2 Normalisation and Evidence Extraction

4.2.1 Description and Priority

Converts preserved artifacts into canonical form and derives the structured evidence that detection consumes: entities, indicators and — critically — **negative** indicators. Extraction is high-recall and carries no score; an observation is not a finding.

Priority: High. (*benefit 9, penalty 9, cost 6, risk 7*)

4.2.2 Stimulus/Response Sequences

#	Stimulus	Response
S1	An artifact enters extraction	System normalises it deterministically, identifies language and script, and extracts entities and indicators
S2	Content contains "Your OTP is 452901. Never share it with anyone."	System extracts both the OTP mention and the self-protective warning as a negative indicator, so the message is not treated as a credential request
S3	Content is in an unsupported language or script	System flags the input as unsupported explicitly and does not silently return a weak result
S4	User corrects a misextracted phone number	System records the correction as user-supplied, re-runs the evaluation, and produces a new analysis without discarding the original

4.2.3 Functional Requirements

ID	Requirement	Pri	Source
REQ-10	The system shall normalise content to a canonical form deterministically, such that the same input always produces the same canonical output.	M	FR-010
REQ-11	The system shall identify the language and script of submitted content.	M	FR-011
REQ-12	The system shall handle code-mixed and transliterated Indian-language input.	P	FR-012
REQ-13	The system shall extract text from screenshots by OCR, recording a per-block confidence value that contributes to evidence quality.	P	FR-013
REQ-14	The system shall extract entities of at least the following types: URL, phone number, UPI VPA, monetary amount, organisation name, application name and account reference.	M	FR-014
REQ-15	The system shall extract indicators across the defined indicator families, and no extracted indicator shall carry a score.	M	FR-015
REQ-16	The system shall detect negative indicators that suppress a rule or reduce risk.	M	FR-016
REQ-17	The system shall allow a user to correct an extraction error and re-evaluate the submission, retaining both the original and corrected extraction.	M	FR-017

4.3 Rule-Based Detection and Scoring

4.3.1 Description and Priority

The decision authority of the product. Evaluates a pinned, versioned rule set against extracted evidence and produces risk, confidence, severity and evidence quality as **four separate quantities**. Rules are composite by construction: no single indicator produces a finding.

Priority: High. (*benefit 9, penalty 9, cost 8, risk 8*) — the highest-risk feature in the product, because both its failure modes damage trust: missing real attacks, and flagging a bank's own anti-fraud message.

4.3.2 Stimulus/Response Sequences

#	Stimulus	Response
S1	Extracted evidence arrives for evaluation	System loads the published rule set, pins its version to this evaluation, evaluates all rules, and records the result
S2	A composite rule's triggers are met across two or more evidence classes	System produces a finding with its contributing indicators and score contribution
S3	A suppression rule's condition is met	System suppresses the affected finding and records the suppression as an explicit outcome, not as an absence
S4	Positive and negative indicators compete	System resolves the conflict by the defined precedence and records which evidence prevailed
S5	Evidence is too thin to conclude	System returns <code>INSUFFICIENT_EVIDENCE</code> rather than a low-risk verdict
S6	An evaluation exceeds the configured uncertainty threshold	System routes the case to human review
S7	A malformed rule, an evaluation timeout or partial evidence occurs	System fails safe: it does not emit a finding derived from an incomplete evaluation, and records the failure
S8	An operator replays a six-month-old evaluation	System re-runs it with the pinned rule-set version and configuration and reproduces the original result exactly

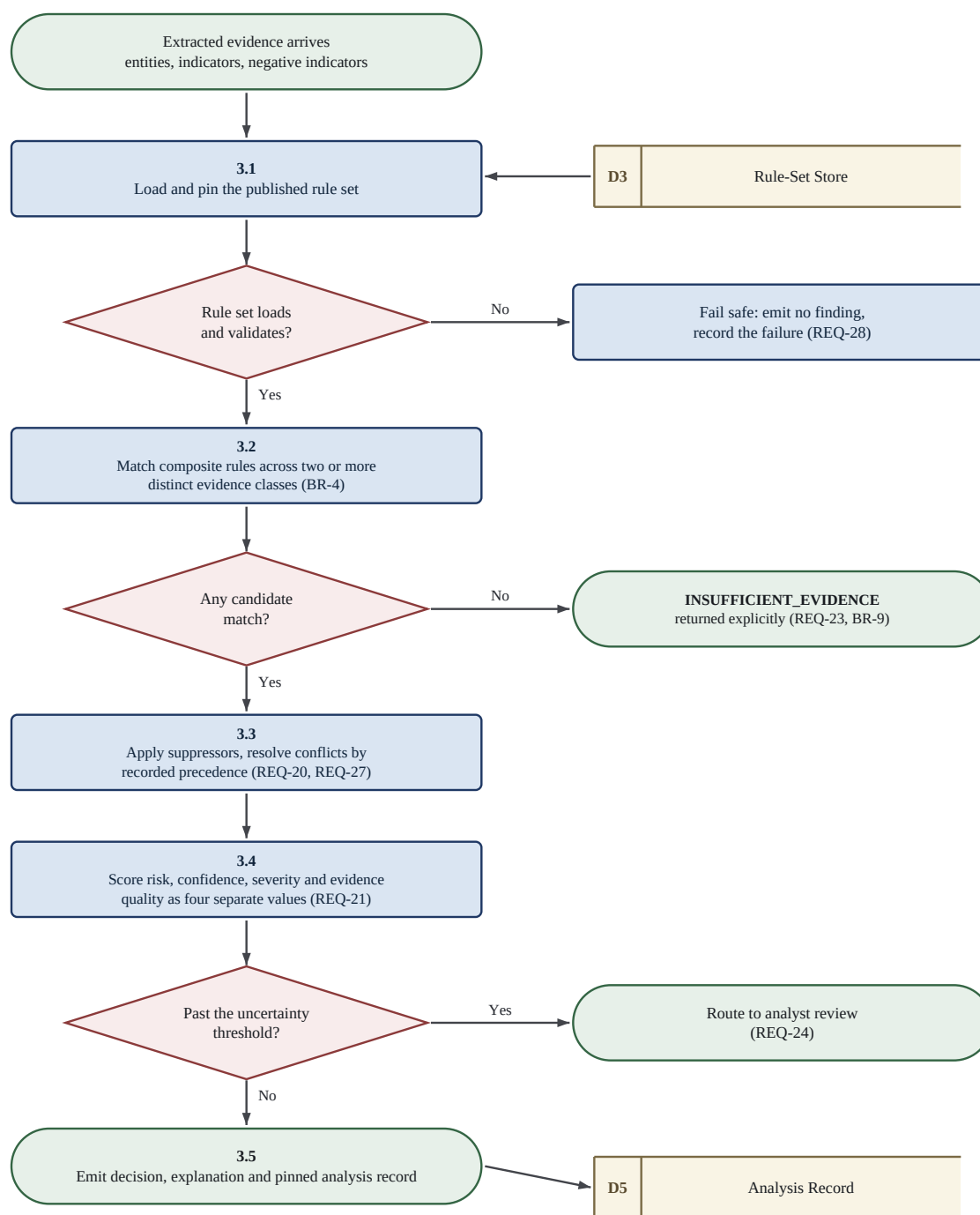


Figure 4 — Control flow through rule evaluation and scoring, showing both fail-safe exits. The order is a requirement, not an implementation choice: suppressors are applied before scoring.

4.3.3 Functional Requirements

ID	Requirement	Pri	Source
REQ-18	The system shall evaluate rules deterministically against extracted evidence.	M	FR-030

ID	Requirement	Pri	Source
REQ-19	The system shall support composite rules that require combinations of indicators spanning at least two distinct evidence classes.	M	FR-031, CONF-002
REQ-20	The system shall support suppression rules, exceptions and exclusions.	M	FR-032
REQ-21	The system shall compute risk, confidence, severity and evidence quality as separate quantities and shall not combine them into a single value at any point in the pipeline or the interface.	M	FR-033, CONF-001
REQ-22	The system shall handle correlated signals without double counting their contribution.	P	FR-034
REQ-23	The system shall return an explicit <code>INSUFFICIENT_EVIDENCE</code> outcome when evidence does not support a conclusion.	M	FR-035
REQ-24	The system shall route evaluations past a configured uncertainty threshold to human review.	M	FR-036
REQ-25	The system shall pin the rule-set version to every evaluation.	M	FR-024
REQ-26	The system shall replay a historical evaluation and reproduce its result exactly.	M	FR-037
REQ-27	The system shall resolve conflicts between competing positive and negative indicators by a defined, recorded precedence.	M	FR-038
REQ-28	The system shall fail safe on a malformed rule, an evaluation timeout or partial evidence, emitting no finding that depends on the incomplete evaluation.	M	FR-039

4.4 Explanation of Findings

4.4.1 Description and Priority

Turns an evaluation into something a person can verify. The requirement is not that the system explains *that* it decided, but that it decomposes *why* — including what it considered and rejected, and why it is not more confident.

Priority: High. (*benefit 9, penalty 9, cost 5, risk 4*)

4.4.2 Stimulus/Response Sequences

#	Stimulus	Response
S1	A verdict is displayed	System presents a plain-language explanation with risk and confidence separately, and an optional technical detail view
S2	User opens the detail view	System lists matched rules with contributing indicators, rules considered but not matched with the reason, negative evidence that reduced risk, and the full score decomposition
S3	Confidence is limited	System states why, and what additional context would raise it
S4	A finding rests on a rule	System surfaces the official source reference supporting that rule, with its provenance grade

4.4.3 Functional Requirements

ID	Requirement	Pri	Source
REQ-29	The system shall report which rules matched, with their contributing indicators.	M	FR-040
REQ-30	The system shall report which rules were considered but did not match, and why.	M	FR-041
REQ-31	The system shall report negative evidence that reduced risk.	M	FR-042
REQ-32	The system shall provide a full score decomposition for each computed component.	M	FR-043
REQ-33	The system shall state why confidence is limited and what context is missing.	M	FR-044
REQ-34	The system shall surface the source references supporting each matched rule, including each source's provenance grade.	M	FR-045
REQ-35	The system shall present a plain-language explanation with an optional technical detail view.	M	FR-046
REQ-36	The system shall describe how an analyst can independently verify a conclusion.	P	FR-047

4.5 Analyst Review and Adjudication

4.5.1 Description and Priority

Human judgement on cases the engine is not confident about. Feedback is captured but never triggers automatic learning — adjudication changes this case, not the rule set.

Priority: Medium. (*benefit 7, penalty 8, cost 4, risk 3*)

4.5.2 Stimulus/Response Sequences

#	Stimulus	Response
S1	A case exceeds the uncertainty threshold	System places it in the review queue with its full decomposition and what did not match
S2	Analyst agrees, disagrees or overrides	System records the adjudication with rationale, writes an audit event, and updates the case
S3	User submits feedback on a finding	System stores the feedback and makes no automatic change to any rule or threshold

4.5.3 Functional Requirements

ID	Requirement	Pri	Source
REQ-37	The system shall present queued cases to an analyst with full score decomposition and the rules that did not match.	M	FR-036, FR-041
REQ-38	The system shall support analyst adjudication with a recorded rationale, and shall write an audit record for every override.	M	FR-063
REQ-39	The system shall capture user feedback on findings without triggering any automatic change to rules, thresholds or scoring.	P	FR-064, NG-08

4.6 Case Management and Report Bundle

4.6.1 Description and Priority

Groups everything about one incident and produces the artifact the user actually leaves with. The bundle's value rests on being reproducible: the same case shall produce an identical bundle later.

Priority: High. (*benefit 8, penalty 9, cost 5, risk 5*)

4.6.2 Stimulus/Response Sequences

#	Stimulus	Response
S1	User requests a report for a case	System assembles evidence with hashes, findings, explanations, source citations and the disclaimer into a structured bundle
S2	User exports the bundle	System delivers it through an authenticated, access-controlled download and records the export in the audit log
S3	The same bundle is regenerated six weeks later	System reproduces an identical bundle from stored evidence and the pinned analysis
S4	A recipient opens the bundle	The disclaimer that this is not an official determination is present and prominent

4.6.3 Functional Requirements

ID	Requirement	Pri	Source
REQ-40	The system shall create and manage cases grouping submissions, findings and analyst notes.	M	FR-051
REQ-41	The system shall generate a structured report bundle conforming to the defined report contract.	M	FR-052
REQ-42	The system shall reproduce an identical report bundle from stored evidence and pinned analysis data.	M	FR-053
REQ-43	The system shall provide report export through an authenticated, access-controlled channel, and shall not transmit a report to any authority automatically.	M	FR-054, NG-01
REQ-44	The system shall carry a prominent disclaimer in every report bundle stating that it is not an official determination of fraud.	M	FR-055, NG-02

4.7 Knowledge Base Governance

4.7.1 Description and Priority

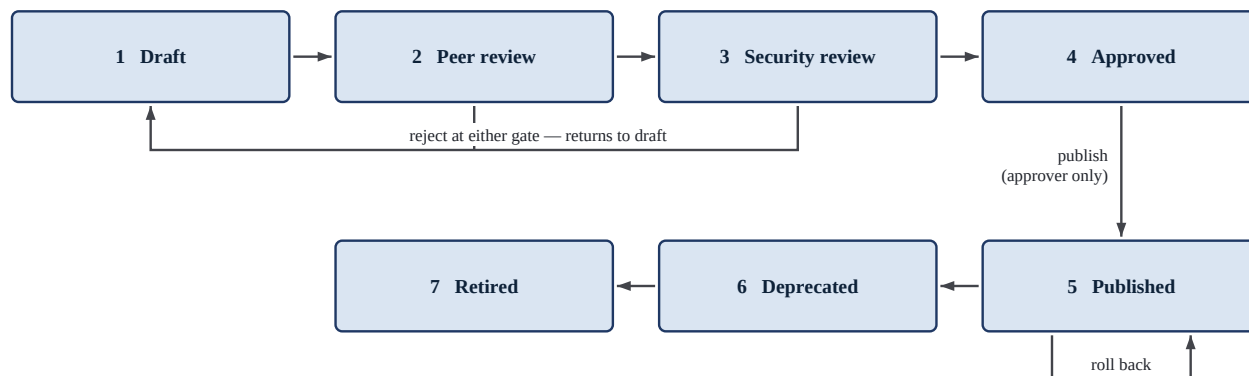
How knowledge enters the product. This feature is the reason a new scam type can be added without touching engine code, and the reason a rule cannot claim evidence it does not have.

Priority: High. (*benefit 9, penalty 9, cost 6, risk 5*)

4.7.2 Stimulus/Response Sequences

#	Stimulus	Response
S1	Editor submits a rule that would fire on a single weak indicator	System rejects it at load time, naming the constraint and the layer that caught it
S2	Editor submits a rule citing a source graded RETRIEVAL_FAILED in the manifest	System rejects the claimed provenance grade
S3	Editor submits a valid draft rule	System validates it against the schema, runs cross-file lint, and produces a review package with diff, impact analysis and regression results

#	Stimulus	Response
S4	Approver publishes a rule set	System creates a new immutable rule-set version; evaluations in flight keep the version they pinned
S5	A published rule set proves harmful	Approver rolls back to a prior version; no historical evaluation changes
S6	A new scam type is added	Editor writes one rule document; no engine code changes



An editor authors and submits (states 1 to 3); only an approver may publish, reject or roll back (BR-5). Rollback restores a prior published rule-set version and changes no completed evaluation, because every analysis pins the version it used (REQ-25, REQ-51).

Figure 5 — The rule lifecycle required by REQ-48, with the rejection path and the rollback that REQ-51 requires. Publication is the only transition an editor cannot perform.

4.7.3 Functional Requirements

ID	Requirement	Pri	Source
REQ-45	The system shall store rules as versioned, schema-validated data and shall not express rule logic as engine code.	M	FR-020, CON-009
REQ-46	The system shall reject any rule failing schema validation or cross-file lint at load time.	M	FR-021
REQ-47	The system shall maintain a versioned scam taxonomy independently of engine code.	M	FR-022
REQ-48	The system shall support the rule lifecycle: draft -> peer review -> security review -> approve -> publish -> deprecate -> retire.	M	FR-023
REQ-49	The system shall require at least one source reference carrying a provenance grade on every non-heuristic rule, and shall require any rule without such a source to be labelled heuristic.	M	FR-025
REQ-50	The system shall reject a rule whose claimed source grade contradicts the source verification manifest.	M	R16, CON-004
REQ-51	The system shall support rollback to a prior published rule-set version without altering any completed evaluation.	P	FR-026
REQ-52	The system shall perform impact analysis when a rule, taxonomy term or source changes.	P	FR-027
REQ-53	The system shall permit a new scam type to be added through data and configuration alone, with no change to engine code.	M	FR-028

4.8 Identity, Access and Audit

4.8.1 Description and Priority

Establishes who may do what, and makes security- and knowledge-relevant actions permanently reviewable.

Priority: High. (*benefit 7, penalty 9, cost 4, risk 4*)

4.8.2 Stimulus/Response Sequences

#	Stimulus	Response
S1	A user authenticates	System establishes a principal with roles and grants only the permitted capabilities
S2	An editor attempts to publish a rule set	System denies the action; publication requires the approver role
S3	A security- or knowledge-relevant action occurs	System writes an immutable audit event with actor, action, target, timestamp and correlation identifier
S4	A user requests export or deletion of their own data	System fulfils the request within the configured retention policy and records audit evidence of doing so

4.8.3 Functional Requirements

ID	Requirement	Pri	Source
REQ-54	The system shall authenticate users.	M	FR-060
REQ-55	The system shall enforce role-based access control across the reporting user, analyst, knowledge editor, knowledge approver and administrator roles.	M	FR-061
REQ-56	The system shall write immutable audit events for security- and knowledge-relevant actions.	M	FR-062
REQ-57	The system shall support data export and deletion requests with audit evidence of fulfilment.	M	FR-065
REQ-58	The system shall apply the configured retention class to submitted content and shall not retain it beyond that class.	M	NG-10, NFR-015

4.9 Enrichment and AI Assistance

4.9.1 Description and Priority

Two optional capabilities behind feature flags. Both are **advisory**: neither may determine an outcome, and the system shall work fully with both switched off.

Priority: Low for release 1.0 (all Post-MVP). (*benefit 6, penalty 3, cost 7, risk 8*) — the highest risk score in the document, because this is where a model could quietly become the decision authority if the boundary is not enforced.

4.9.2 Stimulus/Response Sequences

#	Stimulus	Response
S1	A submission contains a URL and enrichment is enabled	System queries the provider through the adapter and labels the returned verdict as external and non-authoritative
S2	The provider times out or returns an error	System completes the analysis without it and records the degradation
S3	AI assistance is enabled	System sends the content as isolated data, quarantined from model instructions

#	Stimulus	Response
S4	The model returns output that does not conform to the schema	System rejects the output and proceeds deterministically
S5	The model suggests a new rule	System stores it as a draft requiring human approval; it cannot reach a published set without one

4.9.3 Functional Requirements

ID	Requirement	Pri	Source
REQ-59	The system shall integrate URL and threat-intelligence adapters behind a provider-agnostic interface.	P	FR-070
REQ-60	The system shall operate fully when any single external provider is unavailable.	P	FR-071
REQ-61	The system shall gate all AI-assisted capability behind feature flags.	P	FR-072
REQ-62	The system shall validate AI output against strict schemas and shall reject non-conforming output.	P	FR-073
REQ-63	The system shall label model-derived observations distinctly from deterministic findings in storage, API responses and the interface.	P	FR-074
REQ-64	The system shall require human approval before any AI-suggested rule is published.	P	FR-075, NG-07
REQ-65	The system shall degrade to deterministic-only operation when AI assistance is unavailable, with the core path unaffected.	P	FR-076
REQ-66	The system shall isolate submitted content from model instructions so that content cannot alter model behaviour.	P	FR-077

4.10 Analytics

4.10.1 Description and Priority

Operational and knowledge-quality reporting. Reports what the system did — never a claim about how accurate it is (CON-002).

Priority: Low (Post-MVP). (*benefit 5, penalty 3, cost 3, risk 2*)

4.10.2 Stimulus/Response Sequences

#	Stimulus	Response
S1	Approver reviews knowledge quality	System reports rule usage, coverage and contribution
S2	Analyst reviews adjudication history	System reports adjudicated false positives and negatives by category, scoped to the dataset they were measured on
S3	Administrator checks operations	System reports volume, latency and review-queue depth

4.10.3 Functional Requirements

ID	Requirement	Pri	Source
REQ-67	The system shall report rule usage, coverage and contribution.	P	FR-080
REQ-68	The system shall report adjudicated false positives and negatives by category, and shall state the dataset and its limitations alongside any such figure.	P	FR-081, CON-002
REQ-69	The system shall report operational quality including volume, latency and review-queue depth.	P	FR-082
REQ-70	The system shall rate-limit public endpoints and protect them against abuse.	P	NFR-016

5. Other Nonfunctional Requirements

5.1 Performance Requirements

ID	Requirement	Target	Source
NFR-1	Analysis latency for a text-only submission shall meet the stated target at the 95th percentile.	p95 < 2 s	NFR-004 (<i>DERIVED</i>)
NFR-2	Analysis latency for a screenshot submission requiring OCR shall meet the stated target at the 95th percentile.	p95 < 10 s	NFR-005 (<i>DERIVED</i> , <i>Post-MVP</i>)
NFR-3	Rule-set load and validation shall complete before the system accepts traffic; a rule set that fails validation shall prevent startup rather than degrade at runtime.	Startup gate	FR-021

Rationale. The latency budget is seconds, not milliseconds, because users submit content **after** an incident rather than during a live attack (ASM-007, ASM-018). Both targets are *DERIVED* — they were not obtained from a user study, and they are the first figures to revisit if a real user becomes available. They are stated numerically anyway, because an unmeasurable performance requirement is not a requirement.

5.2 Safety Requirements

These concern harm to the **user**, which for this product means acting on a wrong or misunderstood verdict.

ID	Requirement	Source
NFR-4	The system shall not present a verdict in a manner that implies an official determination of fraud.	NG-02, FR-055
NFR-5	The system shall not present recommendations as legal advice; recommended actions shall be safety actions only.	NG-03
NFR-6	The system shall route ambiguous or weakly supported cases to review or return INSUFFICIENT_EVIDENCE rather than presenting an uncertain conclusion as a certain one.	MP Sec. 3, FR-035, FR-036
NFR-7	For coercion scenarios such as digital arrest, the explanation shall contradict the scammer's claim plainly and shall not amplify urgency or fear.	<i>DERIVED</i> from P2
NFR-8	The system shall not block, intercept or modify any message, call or payment.	NG-04
NFR-9	Where the knowledge base cannot support a conclusion in the submitted language, the system shall say so explicitly rather than returning a weak result that reads as safety.	NFR-009, CONF-004

5.3 Security Requirements

ID	Requirement	Source
NFR-10	All data shall be encrypted in transit using TLS 1.3 and at rest using AES-256.	NFR-006
NFR-11	Logs shall contain no secrets, personally identifiable information or raw submitted evidence, verified by automated scanning.	NFR-007, ASM-017
NFR-12	Submitted content shall be treated as sensitive from the moment of ingest, before any classification decision is made about it.	ASM-017

ID	Requirement	Source
NFR-13	Security- and knowledge-relevant actions shall be recorded immutably, covering 100% of the defined event set.	NFR-010
NFR-14	Access to case content shall be restricted by role; the administrator role shall be able to operate the platform without access to submitted content.	FR-061 (DERIVED)
NFR-15	Uploaded files shall be validated and handled so that a malicious upload cannot execute or escape its processing context.	FR-006
NFR-16	Submitted content shall never be interpretable as an instruction by any downstream component, including AI-assisted ones.	FR-077
NFR-17	The system shall not identify or profile individual suspected offenders.	NG-09

Privacy position. Whether India's Digital Personal Data Protection Act 2023 applies to TrustLens **has not been legally verified**, and this document makes no compliance claim (ASM-015). The requirements above are engineering practice, not a legal opinion. Qualified legal review is required — TBD-2.

5.4 Software Quality Attributes

Split deliberately into what can be proven and what cannot. Nothing in the first table depends on having real-world data; nothing in the second may be claimed until it exists.

5.4.1 Provable

ID	Attribute	Requirement	Target	Verified by
NFR-18	Determinism	Identical evidence, rule-set version and configuration shall yield identical output.	100% of golden-case replays	Automated replay suite
NFR-19	Explainability completeness	No finding shall exist without a complete evidence -> rule -> source trace.	100% of findings	Property test
NFR-20	Extensibility	A new scam type shall be addable with no engine code change.	0 engine lines changed	Integration test
NFR-21	Correctness of knowledge	Every published rule shall pass schema validation and cross-file lint.	100%	CI gate
NFR-22	Traceability	Every non-heuristic published rule shall carry a graded source reference; every rule without one shall be labelled heuristic.	100%	CI gate
NFR-23	Accessibility	MVP journeys shall meet WCAG 2.2 AA.	Pass	Automated + manual audit
NFR-24	Testability	Automated gates shall exist at unit, schema, property, integration, contract and end-to-end levels.	CI-enforced	CI
NFR-25	Reproducibility	A clean clone shall build and run without manual intervention.	Green from scratch	CI
NFR-26	Observability	All services shall emit structured logs with correlation identifiers, metrics and health checks.	All services	Operational review
NFR-27	Maintainability	A new scam type shall be addable by a knowledge editor without developer involvement.	Proven by test	Integration test
NFR-28	Availability of core path	The core analysis path shall complete when enrichment or AI assistance is unavailable.	Core path unaffected	Fault-injection test

5.4.2 Not provable within this programme

Precision, recall, false-positive rate, false-negative rate, calibration and abstention quality cannot be claimed. No labelled real-world corpus exists and none is obtainable (G-09, RSK-003). A synthetic corpus supports determinism and regression detection only. Any figure produced against synthetic data shall be reported with its dataset scope and limitations attached, and shall never be presented as a general accuracy claim (CON-002, NG-06).

5.5 Business Rules

ID	Rule
BR-1	The rule engine decides. AI assists interpretation and extraction; it never overrides deterministic evidence and is never the final decision authority.
BR-2	Risk and confidence are separate quantities and are never collapsed into one number, anywhere.
BR-3	A new scam type is added through data, not code.
BR-4	No rule fires on a single indicator. Every published rule requires a combination spanning at least two distinct evidence classes.
BR-5	Publication requires two roles. A knowledge editor may author and submit; only a knowledge approver may publish, reject or roll back. During development the same person may hold both roles, but the system enforces the separation regardless (ASM-019).
BR-6	A rule may not claim evidence it does not have. A rule whose source grade contradicts the verification manifest cannot be published, and an <code>UNSUPPORTED</code> or <code>HEURISTIC</code> rule cannot enter the published set at all.
BR-7	TrustLens files nothing on anyone's behalf. Report bundles leave only through a user-initiated, access-controlled export.
BR-8	Feedback never auto-trains. No user or analyst action changes a rule, threshold or score without human adjudication and the approval workflow.
BR-9	Uncertainty is shown, not hidden. <code>INSUFFICIENT_EVIDENCE</code> is a first-class outcome, not a failure state.
BR-10	Synthetic content is labelled synthetic and never presented as a real sample.
BR-11	Administrators operate; they do not read cases. Platform administration does not carry access to submitted content.

6. Other Requirements

Database requirements. Evidence, cases, findings, pinned analyses and audit events shall be persisted such that: an evaluation's inputs and rule-set version remain retrievable for replay for the full retention period; audit events are append-only; and deletion under retention policy or a user request removes submitted content while leaving audit evidence that the deletion occurred.

Internationalisation. All user-facing text shall be externalised for translation from the first release, and language and script shall be first-class dimensions of the rule schema rather than a later retrofit — even though release 1.0 ships English content only. The system shall declare which languages it supports and flag unsupported input. **Which Indian languages enter MVP scope is undecided** — TBD-4.

Legal requirements. TrustLens holds no regulatory registration, official status or relationship with any body whose guidance it cites (ASM-008). Every report bundle and every verdict view shall carry the non-official-determination disclaimer. No statement in the product shall assert a regulatory obligation that has not been verified against a primary source (CON-004).

Reuse objectives. The rule schema, indicator registry, scam taxonomy and source verification manifest are designed as portable data artifacts, independent of the engine that consumes them, so that a future device-side or partner component can reuse them without reimplementing.

Requirements deliberately excluded from this SRS, per IEEE 830 and the course notes: project cost, delivery schedule, staffing and reporting procedures; design solutions such as module partitioning and data-structure choice; and product assurance procedures such as QA, configuration management and verification plans. Those live in the programme's roadmap, ADRs and test strategy respectively.

Appendix A: Glossary

Terms are **normative**: where they appear in TrustLens artifacts, code or interface, they carry exactly this meaning. The four decision quantities are deliberately kept distinct because the programme forbids collapsing them into one number (CONF-001).

Decision quantities

Term	Definition	What it is not
Severity	How much harm the scam pattern would cause <i>if the finding is correct</i> . A property of the scam class, largely fixed per rule. Ordinal: LOW, MEDIUM, HIGH, CRITICAL.	Not a measure of whether the pattern is present.
Risk	Computed exposure for <i>this specific submission</i> : a function of severity and the strength of matched evidence. Bounded, decomposable, reproducible.	Not a probability, and not "how sure we are".
Confidence	How much the system trusts its own analysis of this submission — extraction quality, corroboration across independent indicators, completeness of context.	Not risk. A confident finding may be low-risk.
Evidence quality	Reliability of the <i>inputs</i> — OCR fidelity, truncation, known sender, enrichment success. Feeds confidence.	Not the reliability of the rule's source.
Signal strength	Contribution of a single indicator or rule match before aggregation.	Not the final score.
Trust	Reliability weight of a knowledge <i>source</i> or provider. A property of the source.	Not confidence in the finding.

Pipeline and domain terms

Term	Definition
Submission	One user act of sending content for analysis. Contains one or more artifacts.
Artifact	A single piece of submitted content — text body, URL, image, email source. Immutable once stored.
Normalisation	Deterministic conversion of an artifact to canonical form without discarding the original.
Extraction	Deriving entities and indicators from normalised content.
Entity	A concrete identifiable thing found in content — URL, phone number, UPI VPA, amount, organisation, app name, account reference.
Indicator	An observed signal belonging to an indicator family (e.g. CREDENTIAL_REQUEST, SECRECY_DEMAND). Carries no score.
Negative indicator	An observed signal that reduces risk or suppresses a rule — e.g. "never share this OTP".
Rule	A versioned, declarative, source-referenced statement that a named combination of indicators constitutes a recognised scam pattern. Stored as validated data, not code.
Rule set	A versioned collection of rules published together. Evaluations pin the version.
Evaluation	One deterministic execution of a rule set against one submission's extracted evidence.
Finding	A single rule match, with contributing indicators, score contribution and source references.
Decision	The overall classified outcome across all findings, including INSUFFICIENT_EVIDENCE.

Term	Definition
Explanation	The account of a decision: what matched, what did not, what reduced risk, why confidence is limited, how to verify.
Case	A durable container grouping submissions, evidence, findings, notes and reports for one incident.
Evidence item	An artifact plus its integrity metadata — hash, capture timestamp, chain-of-custody record.
Report bundle	A reproducible, exportable package assembled from a case. Assists reporting; not an official determination.
Adjudication	An analyst's recorded judgement on a finding or case, including rationale.
Provenance	The recorded origin of a knowledge item: which source, which advisory, retrieved when, verified how.
Replay	Re-running a historical evaluation with its pinned rule-set version to reproduce the original result exactly.

Evidence and provenance grades

Grade	Meaning
PRIMARY_VERIFIED	The issuing body's own document was retrieved and the specific claim located within it.
PRIMARY_CITED_UNVERIFIED	A specific primary document is cited but has not been retrieved and checked.
INDEX_ONLY	The citation resolves to a listing or index page, not a document substantiating the claim. Insufficient alone.
SECONDARY	The claim comes from a synthesis or commentary about a primary source.
HEURISTIC	An engineering judgement with no source claim. Must be labelled as such.
SYNTHETIC	Example content authored for testing. Never presented as a real sample.

India-specific terms

Term	Definition
UPI	Unified Payments Interface — India's real-time retail payment system, operated by NPCI.
UPI PIN	The secret authorising <i>sending</i> money via UPI. Receiving money never requires it — a boundary underpinning several rules.
VPA	Virtual Payment Address, the <code>name@bank</code> identifier used to address UPI payments.
OTP	One-Time Password. Note the distinction between a message <i>delivering</i> one and a message <i>requesting</i> one (CONF-002).
KYC	Know Your Customer — regulated identity verification; a frequent scam pretext.
Digital arrest	A coercion scam impersonating law enforcement, alleging criminal involvement, imposing secrecy and extracting payment under threat of arrest.
Smishing / Vishing	Phishing conducted over SMS / voice call respectively.
USSD	Telephony short codes (e.g. *21#), abused to silently enable call forwarding.
APK / sideloading	Installing Android apps outside the official store — a malware delivery vector.

Organisations

Abbrev.	Body	Authority level
I4C	Indian Cybercrime Coordination Centre, Ministry of Home Affairs	Official (government)
NCRP	National Cyber Crime Reporting Portal	Official (government)
CERT-In	Indian Computer Emergency Response Team	Official (government)
RBI	Reserve Bank of India	Official (regulator)
NPCI	National Payments Corporation of India	Official (payment system operator)
SEBI	Securities and Exchange Board of India	Official (regulator)
DoT	Department of Telecommunications	Official (government)
Sanchar Saathi / Chakshu	DoT citizen portal for reporting suspected fraud communication	Official (government)
Commercial organisations (banks, platform companies)	—	Not authorities. Corroborating industry guidance only (CONF-005).

Document and programme terms

Term	Definition
SRS	This document — the statement of what developers shall implement.
Quality gate	A named, evidence-checked condition that must hold before a phase counts as approved input to the next. Reported PASS, PARTIAL or BLOCKED.
MVP	Release 1.0 scope: "a verifiable verdict on a text message", including evidence preservation, case and report bundle.
DFD	Data Flow Diagram — the analysis model used in Appendix B. Levels 0, 1 and 2 are drawn as Figures B-1 to B-5.

Appendix B: Analysis Models

Five data flow diagrams model the system: one context diagram, three panels that together form the level-1 decomposition, and one level-2 explosion of process 3.0. They are balanced against each other — every flow at level 0 reappears in exactly one level-1 panel, and every flow belonging to process 3.0 reappears at level 2.

Notation. DeMarco and Yourdon. An **oval** is a process, a **rectangle** is an external entity (terminator), and an **open rectangle** carrying its identifier in a left-hand compartment is a data store. A **dashed outline** marks a Post-MVP element. Level 0 contains no data store, by convention.

The same models are held in PlantUML source form at docs/05-architecture/diagrams/TrustLens-DFD-L0.puml, -L1.puml and -L2.puml (R21). Where a diagram and the requirement text disagree, the requirement text governs.

Level 0 — context

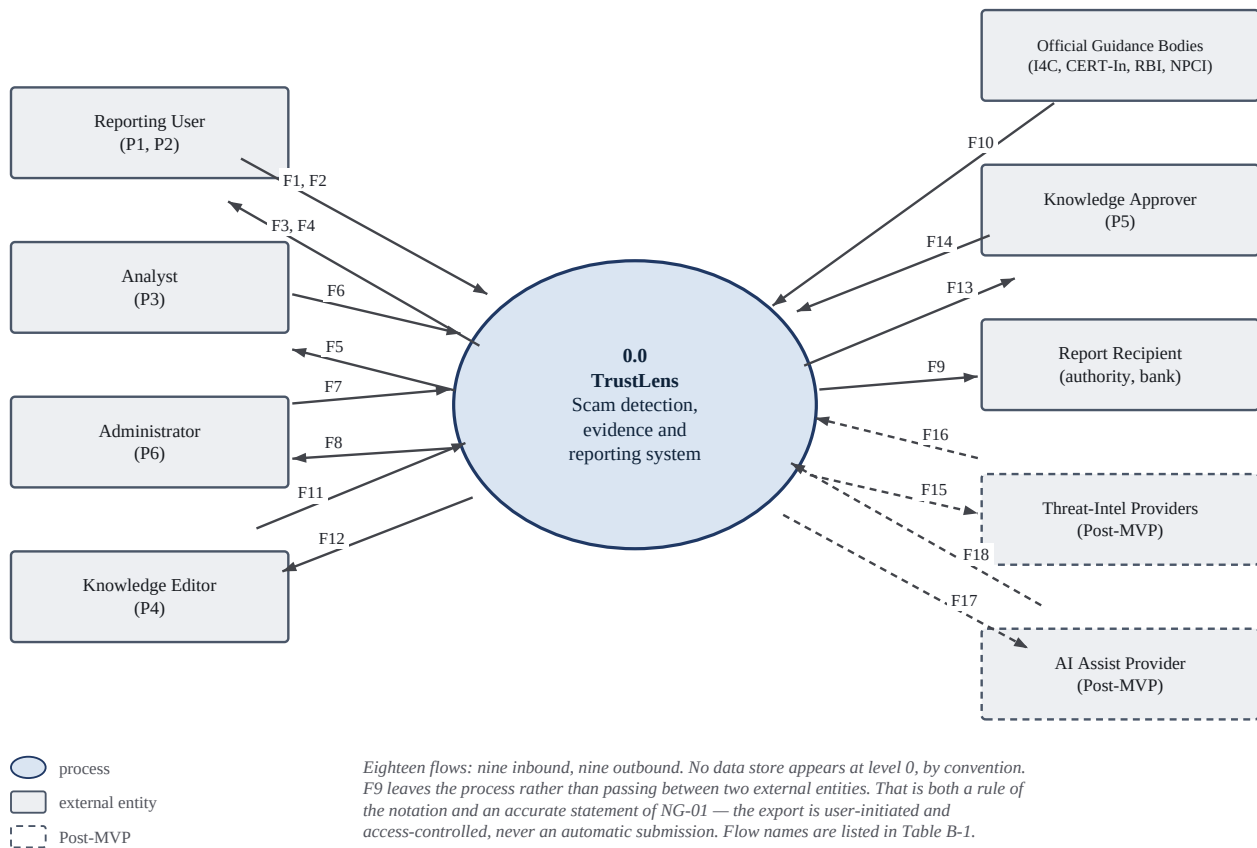


Figure B-1 — Level 0 context diagram. One process, nine external entities, eighteen flows, no data stores. Flow names are given in Table B-1.

Two modelling points are load-bearing:

- **F9, the report export, leaves process 0.0** — it is not drawn as a hand-off between two external entities. That is both a DFD legality requirement and an accurate statement of NG-01: the export is access-controlled and user-initiated, and nothing is submitted automatically.

- **The AI assist provider sits outside the boundary**, with schema-checked drafts returning inward, which is NG-07 expressed structurally rather than as prose.

Table B-1 — Flow register. Every flow crossing the system boundary, with the level-1 process that owns it.

Flow	Name	From	To	Requirement
F1	Submitted artifacts	Reporting user	1.0	REQ-1 to REQ-5
F2	Corrections and re-evaluation request	Reporting user	2.0	REQ-17
F3	Verdict and evidence trace	4.0	Reporting user	REQ-29 to REQ-35
F4	Report bundle	6.0	Reporting user	REQ-41
F5	Queued case with full score decomposition	5.0	Analyst	REQ-37
F6	Adjudication and rationale	Analyst	5.0	REQ-38
F7	Configuration and retention policy	Administrator	8.0	REQ-58
F8	Health, audit and metrics	8.0	Administrator	REQ-56, REQ-69
F9	Access-controlled report export	6.0	Report recipient	REQ-43
F10	Published advisories	Guidance bodies	7.0	REQ-49, REQ-50
F11	Draft rule with source references	Knowledge editor	7.0	REQ-45
F12	Schema and lint verdict	7.0	Knowledge editor	REQ-46
F13	Review package — diff, impact analysis, regression	7.0	Knowledge approver	REQ-48, REQ-52
F14	Publish, reject or roll back decision	Knowledge approver	7.0	REQ-48, REQ-51
F15	Reputation lookup (<i>Post-MVP</i>)	3.0	Threat-intel providers	REQ-59
F16	Provider verdict, labelled non-authoritative (<i>Post-MVP</i>)	Threat-intel providers	3.0	REQ-59, REQ-63
F17	Isolated content prompt (<i>Post-MVP</i>)	2.0	AI assist provider	REQ-66
F18	Schema-checked draft (<i>Post-MVP</i>)	AI assist provider	7.0	REQ-62, REQ-64

Nine flows enter the system (F1, F2, F6, F7, F10, F11, F14, F16, F18) and nine leave it (F3, F4, F5, F8, F9, F12, F13, F15, F17).

Level 1 — decomposition

Level 1 explodes process 0.0 into eight processes and six data stores. It is drawn as three panels so that each stays legible at page width. **The three panels are one diagram:** every level-0 flow appears in exactly one panel, and no flow appears twice. Where a process in one panel exchanges data with a process in another, the counterpart is drawn as a labelled reference box rather than repeated.

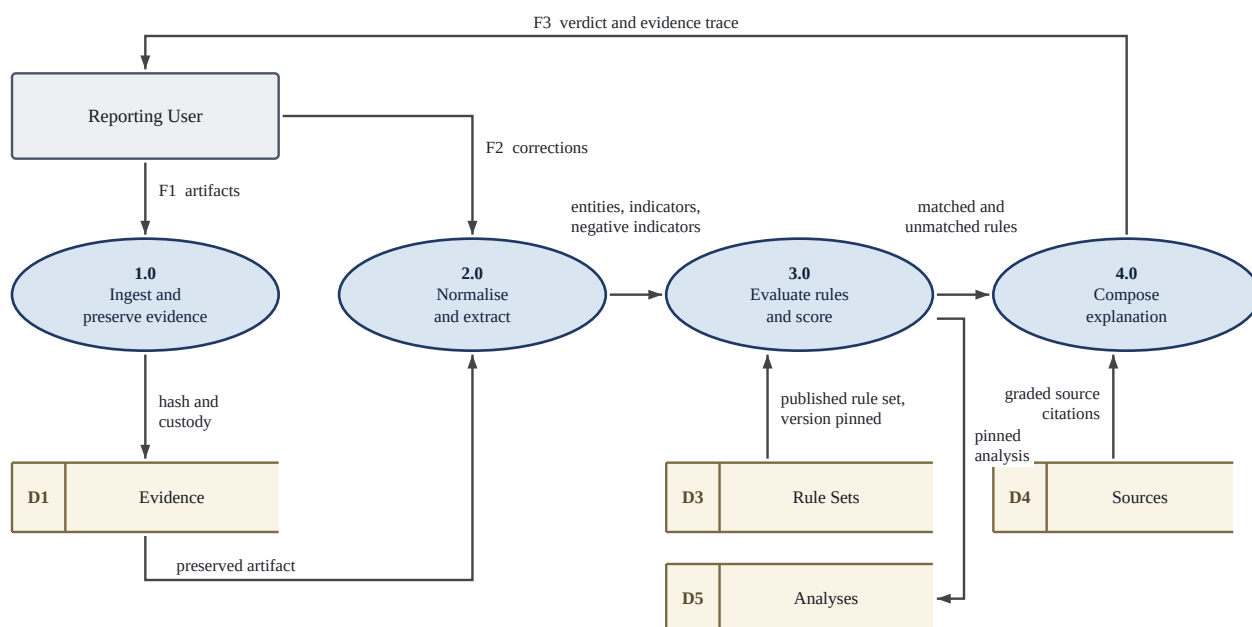


Figure B-2 — Level 1, panel A: ingest, normalisation, evaluation and explanation. This is the path every submission takes, and the path that must complete when enrichment and AI assistance are off.

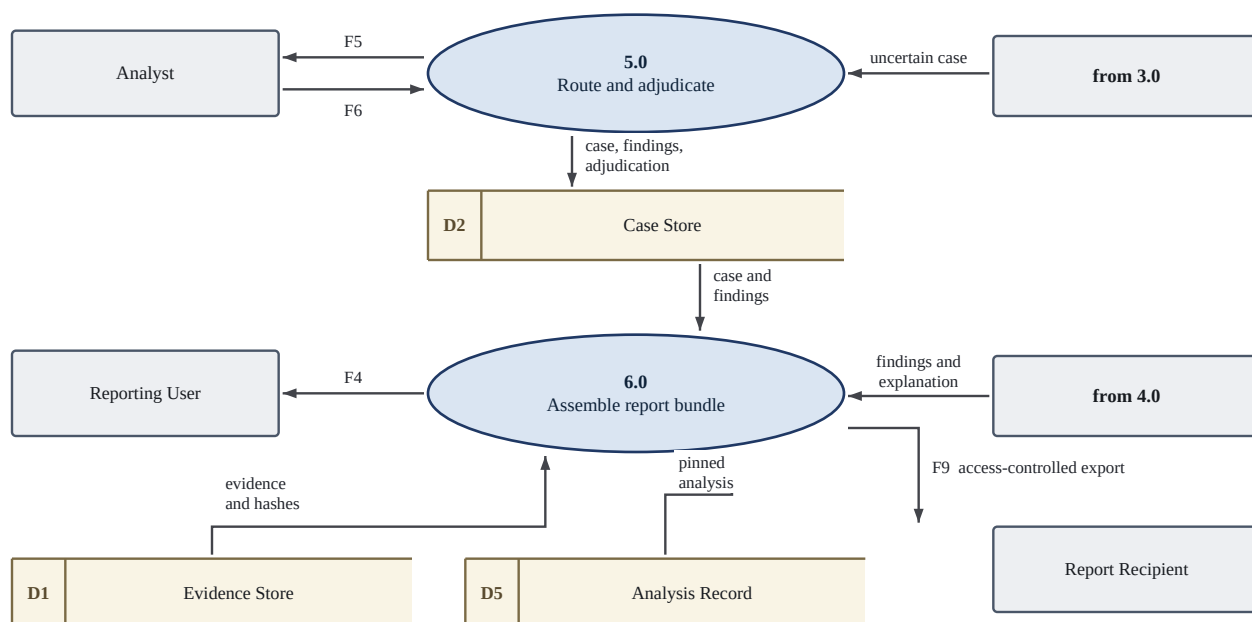
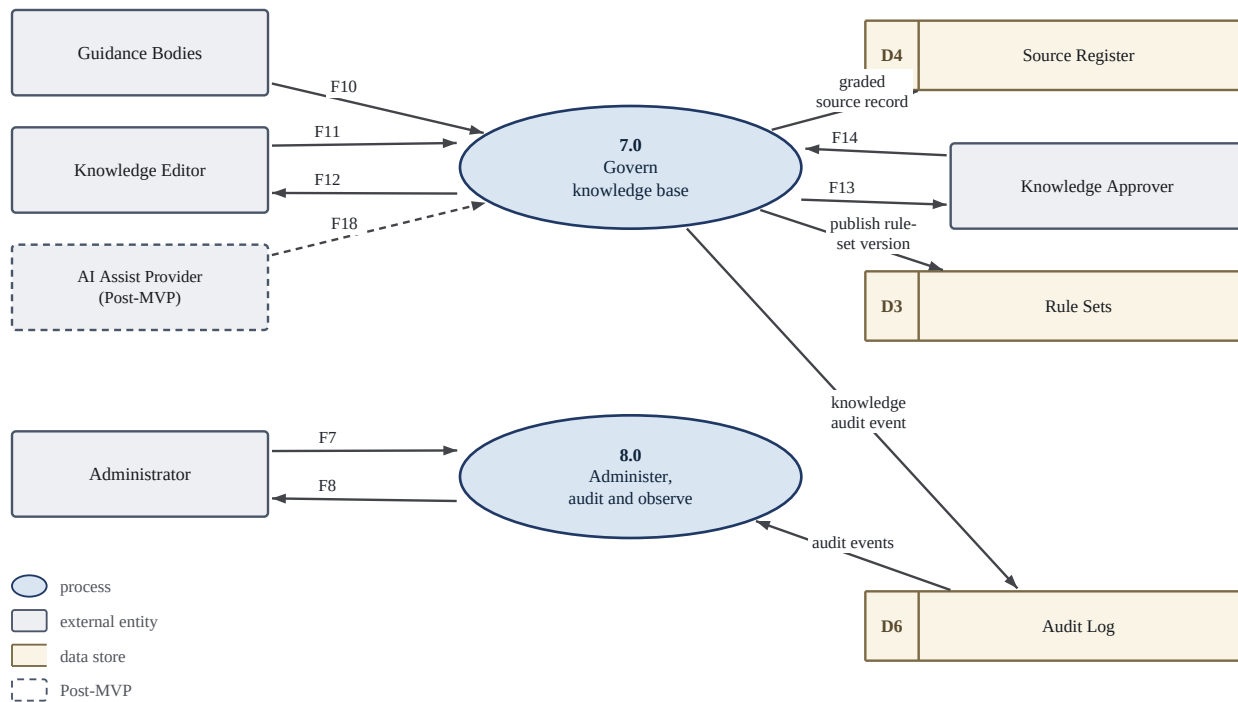


Figure B-3 — Level 1, panel B: adjudication and report assembly. Process 6.0 draws on three stores, which is what makes an identical bundle reproducible months later (REQ-42).



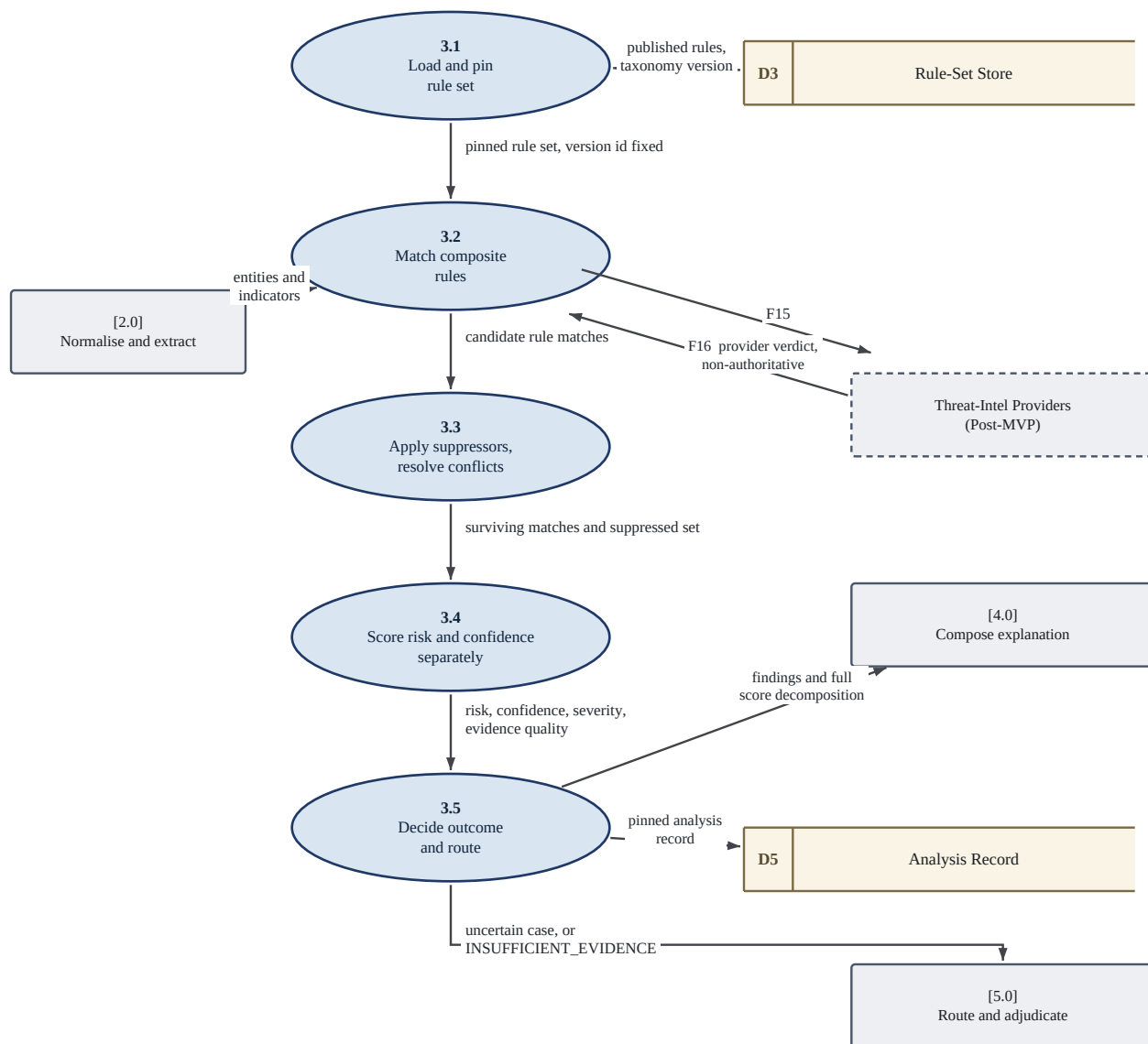
Process 7.0 is why a new scam type is added by writing one rule document rather than by changing engine code (REQ-53, BR-3). Process 8.0 holds no case content; the administrator role operates the platform without read access to submissions (BR-11).

Figure B-4 — Level 1, panel C: knowledge governance and administration. Nothing reaches the rule-set store except through 7.0, and 7.0 has no path to a case.

Process	Panel	Inherits level-0 flows
1.0 Ingest and preserve evidence	A	F1
2.0 Normalise and extract	A	F2, F17
3.0 Evaluate rules and score	A	F15, F16
4.0 Compose explanation	A	F3
5.0 Route and adjudicate	B	F5, F6
6.0 Assemble report bundle	B	F4, F9
7.0 Govern knowledge base	C	F10, F11, F12, F13, F14, F18
8.0 Administer, audit and observe	C	F7, F8

Store	Contents	Written by	Read by
D1 Evidence Store	Artifacts with hash and chain-of-custody metadata	1.0	2.0, 6.0
D2 Case Store	Cases, findings, analyst notes and adjudications	5.0	6.0
D3 Rule-Set Store	Immutable published rule-set versions	7.0	3.0
D4 Source Register	Graded source records and the verification manifest	7.0	4.0
D5 Analysis Record	Pinned inputs, rule-set version and scores, for replay	3.0	6.0
D6 Audit Log	Append-only security- and knowledge-relevant events	5.0, 7.0, 8.0	8.0

Level 2 — process 3.0, evaluate rules and score



Five sub-processes; the ceiling for a level-2 explosion is nine. Process 3.3 runs before 3.4 by requirement: suppressors are applied before scoring, so negative evidence cannot be out-voted afterwards (REQ-20, REQ-27).

Figure B-5 — Level 2: process 3.0 exploded into five sub-processes. The ordering carries a requirement — 3.3 runs before 3.4.

3.1 Load and pin rule set -> 3.2 Match composite rules -> 3.3 Apply suppressors and resolve conflicts -> 3.4 Score risk and confidence separately -> 3.5 Decide outcome and route.

The ordering carries a requirement: **suppressors run before scoring**, so negative evidence cannot be out-voted after the fact (REQ-20, REQ-27). 3.5 writes the pinned analysis record that makes REQ-26 replay and REQ-42 report reproduction possible.

Appendix C: To Be Determined List

Every unresolved item in this SRS, tracked to closure. Nothing in this list is hidden elsewhere in the document as though it were settled.

ID	Item	Blocks	Needed from	Reference
TBD-1	No end user, analyst or knowledge editor has validated any persona, journey or <i>DERIVED</i> requirement.	Confidence in Sections 2.3 and 4	Sponsor — access to even one real user	ASM-001, OI-01
TBD-2	Data retention period and legal basis undecided; DPDP applicability unverified and no compliance claim made.	REQ-57, REQ-58, NFR-15, Section 6	Sponsor + qualified legal review	ASM-015, OI-05
TBD-3	Docker and PostgreSQL are not installed on the development machine.	All implementation	Sponsor (administrative install)	RSK-006, OI-02
TBD-4	Which Indian languages are in MVP scope. Currently English-only by default, and no verified source supplies non-English cues.	REQ-12, NFR-9, Section 6 internationalisation	Sponsor decision	CONF-004, G-08, OI-04
TBD-5	Default evidence retention is 90 days as a placeholder, not a policy decision.	REQ-58	Sponsor	ASM-014
TBD-6	Deployment target unknown — local-only or a hosted environment.	Section 2.4, operational requirements	Sponsor	OI-06
TBD-7	Identity provider not selected (SI-8).	REQ-54	Architecture decision, Phase 5	—
TBD-8	OCR engine not selected, and no guidance exists on OCR quality for Indian scripts.	REQ-13, NFR-2	Empirical evaluation	G-15
TBD-9	The negative-indicator library does not yet exist; the research package supplies zero suppressive signals.	REQ-16, REQ-20 — and therefore the false-positive strategy	Knowledge work package, Phase 2	G-07
TBD-10	Reduction mathematics for REDUCE-type suppression rules is undefined; only SUPPRESS is currently expressible.	REQ-20, REQ-27	Detection design phase	ADR-0003
TBD-11	Seven I4C-attributed rule bases, the PIB fraud statistic and three commercial-source rule bases remain unretrievable, so the rules resting on them stay unpublished.	Detection coverage at release	Manual retrieval on an Indian network	G-01, G-03, G-04
TBD-12	No labelled real-world corpus exists, so accuracy is unmeasurable. Unclosable within this programme — recorded so it is never quietly forgotten.	Section 5.4.2, any accuracy claim	Out of scope; permanent disclosure required	G-09, RSK-003
TBD-13	Sextortion appears in Chakshu's official reporting categories but is absent from the scam taxonomy.	Taxonomy completeness	Knowledge work package	G-10
TBD-14	Loan-app abuse and mule-account categories carry zero cited sources.	Detection coverage	Dedicated research pass	G-12
TBD-15	Programme has no end date, so no requirement in this document is time-boxed.	Release planning	Sponsor	ASM-009, OI-03

End of SRS-001 v1.1.